PASS Data Community Summit

Host redgate

Mom/Daughter Duo: DBA Teaches Data Engineer Security Secrets Worth Stealing

Sharon Reid, Allison Harris

he, her

Staff DBA

NISA

Data Engineer

NFP



Sharon Reid

She/Her



Staff DBA

NISA Investment Advisors

Before the commencement of her reign as the "Database Security Czarina of NISA," Sharon Reid was an adjunct English professor. Sharon enjoys sharing her passion for database security and is determined to make it fun, practical and implemented.

linkedin.com/in/SharonReidDBA

https://github.com/InfoJunkie1/PASS_SecuritySecrets

Allison Harris

She/Her

Data Engineer

NFP



Allison enjoys building reliable data pipelines that turn raw, messy inputs into clean, trusted datasets for analytics and apps.

linkedin.com/in/allison-harris-8a3ab3207

https://github.com/InfoJunkie1/PASS_SecuritySecrets

Expectations

- Basic understanding of databases and ETL processes—no security background needed
- Not a compliance lecture—practical patterns you can implement Monday
- Willingness to ask questions and share your own war stories

Two Worlds

- DBA: stability, optimization, protection—"every permission is a promise"
- Data engineer: speed and scale—"every delay is a broken promise to the business"
- Deadlines push shortcuts: db_owner, hardcoded passwords, prod data in dev
- When it comes to security, these worlds can't stay separate

Secrets Worth Stealing

1. Least privilege—access is a loan, not a gift
2. Secrets management—if it's in the code, it's compromised
3. Non-prod is where prod data goes to leak
4. Auditing—who did what, when?

Secret #1—Least Privilege

- Only the access people need, when they need it
- Securables: tables, views, sprocs, schemas we grant or deny on
- Direct grants on securables, schema-scoped—not db_owner
- Temporary! Don't grant permanent permissions for temporary problems

PASS
Data Community Summit

Four Moves for a Pipeline Identity

The Monday-morning checklist.

1. **One identity per pipeline group** — not one shared etl_service for twelve jobs.
2. **Write what it does, as verbs on objects** — SELECT source, INSERT/UPDATE staging, EXECUTE its own procs. That list is the permission set.
3. **Grant at the schema level, scoped to those verbs** — never at the database level. db_datareader is db_owner's quieter cousin.
4. **Verify as the account, not as yourself** — impersonate it and ask what it can do. "Works for me" proves nothing.

Don't guess the list — start from zero and let the errors tell you. The first green run is your least-privilege spec.

PASS Data Community Summit

Elevated Permissions—The Usual Suspects

- TRUNCATE TABLE, SET IDENTITY_INSERT
- Audit logs and DMVs (VIEW SERVER STATE)
- Cross-database access and dynamic SQL
- Three ways out: ownership chaining, impersonation, module signing
- Signing wins: context never changes, and ALTER breaks the signature

Temporary Means Temporary

- Version 1: Post-Its on the monitor
- Version 2: reminder table + expiration email (still manual)
- Version 3: automated process—nightly job removes expired permissions
- Works at database and server level, roles or securables
- github.com/InfoJunkie1/TempPerms

Demo—Least Privilege

- Grants as the pipeline's job list: read src, write staging, execute etl
- Ask the account itself: fn_my_permissions
- src.Orders works. dbo.Payroll — permission denied
- Signed sproc: TRUNCATE without elevation
- ALTER the sproc—watch the signature (and the elevation) vanish

Secret #2—Where Credentials Hide

- Notebooks, config files, "temporary" test scripts
- Git history is forever
- Orchestrator variables visible to every developer
- One shared service account for twelve pipelines

The Escalation Ladder

- Hardcoded → environment variable → secret vault → managed identity
- Each rung removes a whole class of leak
- Managed identity: the best secret is no secret
- Databricks secret scopes: print(pwd) → [REDACTED]

Demo—Where Credentials Hide

- The evolution of one connection (Python): four rungs
- Stage 0 is in git forever—deleting the file doesn't delete the commit
- Stage 3: look closely—there is no password in the string at all
- Databricks secret scopes: print(pwd) → [REDACTED]

Encrypt Those Connections!

- Data in transit is inherently vulnerable—seal the envelope
- Encrypt=True in every connection string
- TrustServerCertificate=False—"True" invites man-in-the-middle

Secret #3—Non-Prod Is Where Prod Data Goes to Leak

- Copying prod to dev: legitimate need, wrong solution
- Prod's data without prod's controls: more people, weaker auditing, laptops, Slack
- Breaches love lower environments

Three Masking Tools

- Dynamic data masking: fast but thin (presentation layer only)
- Static masking on refresh: the workhorse
- Synthetic data (Faker): best for demos and CI
- Make masking a pipeline step, not a request you file with the DBA

Demo—Data Masking

- Dynamic data masking (T-SQL)—and why it's presentation-layer only
- Static masking as the last step of the dev refresh
- Synthetic customers with Faker (Python), seeded for CI
- “None of these people exist—and the pipeline can't tell the difference”

Secret #4—Who Did What?

- Nightly snapshot of server and database permissions
- Morning report: yesterday's changes only—nobody reviews 10,000 permissions; everybody reviews yesterday's 3 changes
- Script-form backups: dropped permissions = 30-second fix

Pipeline-Side Traceability

- Every run records: run id, identity, step, target, rows, status
- Lineage is your audit trail
- Audit output goes where the pipeline identity can't modify it
- An audit trail you can edit is a diary, not evidence

Demo—Who Did What When

- Permissions delta report catches a live sketchy GRANT
- Structured audit events (Python): run id, identity, step, target, rows, status
- It ships where the pipeline identity can't edit it

The Risk Checklist

- Cleartext connections
- Service account sprawl
- Permission creep by 2 a.m. retry
- Staging tables, CSV dumps, notebooks committed to git
- Orchestrator secrets in plain sight

The 60-Second Self-Audit

- Does the pipeline identity have more than it uses?
- Could you rotate every credential today?
- Is prod data sitting in dev right now?
- Can you say who changed permissions yesterday?
- Would an unencrypted connection be noticed?

Speaking the Same Security Language

- Shared vocabulary: least privilege, secrets, masking, audit
- A process throughout the pipeline—not a gate at the end
- Security shifts from gatekeeping to collaboration
- "She taught me Python. I taught her paranoia. Steal both."

References—Steal These Too

- Ditching the Post-Its: Automating Temporary Permissions (DataGrillen)
- Signing Sprocs for Elevated Permissions (StL SQL Server & BI UG)
- Protecting the Kingdom: Permissions Monitoring (StL SQL Server & BI UG)
- Using Encrypted Connections (StL SQL Server & BI UG)
- Today's demo code: github.com/InfoJunkie1/PASS_SecuritySecrets

Your feedback is important to us

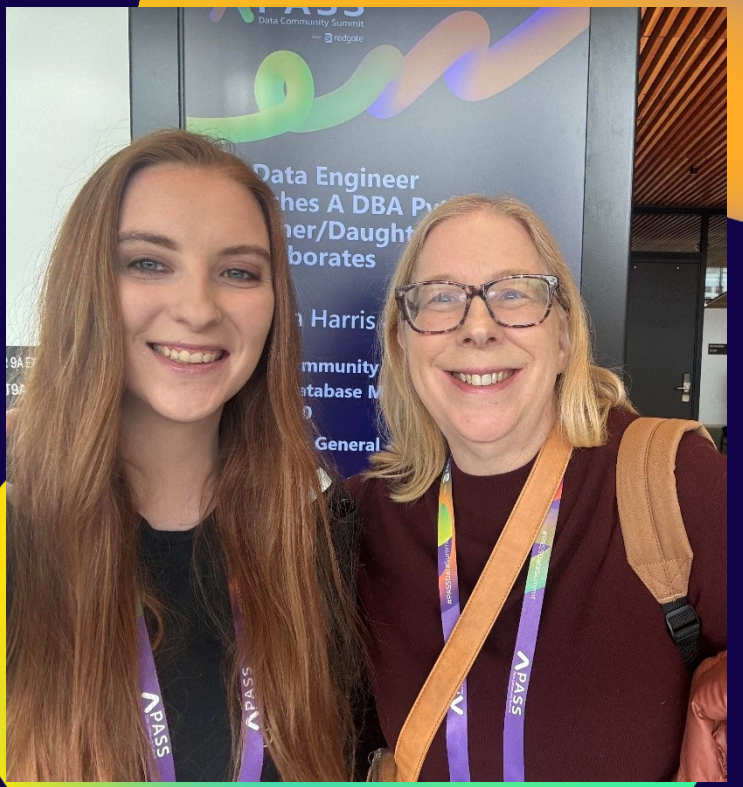


Evaluate this session at:

passdatacommunitysummit.com/evaluations

Thank you

We enjoyed sharing our story with you and would love to stay in touch!



Sharon Reid, Allison Harris

linkedin.com/in/SharonReidDBA

linkedin.com/in/allison-harris-8a3ab3207

https://github.com/InfoJunkie1/PASS_SecuritySecrets